

Separating Secrets from Placeholders: A Hybrid CNN-CodeBERT Framework for Three-Class Credential Leakage Detection

Maksuda Bilkis Baby¹, Khusika Shah², Naiyue Liang¹, and Lei Zhang¹

¹Information Systems, University of Maryland, Baltimore County, USA

²Computer Science and Electrical Engineering, University of Maryland, Baltimore County, USA
mstmakb1, kshah7, vs76219, leizhang@umbc.edu

Abstract—Credential leakage in public source code repositories poses a critical security threat, with over 23.8 million secrets exposed in 2024 alone. Existing detection tools suffer from high false-positive rates because rigid pattern matching and binary classification schemes fail to distinguish genuine credentials from placeholder or weak credentials. We propose a three-class classification framework that explicitly models placeholder or weak credentials as a distinct class, leveraging CodeBERT-based semantic understanding combined with character-level pattern recognition. We evaluate our approach on a newly constructed dataset of 9,426 samples spanning 10 programming languages. Our model achieves a Matthews Correlation Coefficient of 0.86 and a macro F1-score of 0.90, achieving 93% recall and 89% precision for genuine credential leaks while reducing high-severity alerts by 33.0% (from 373 to 250) without sacrificing security coverage. Compared to prior character-level approaches, our method improves placeholder or weak credential detection from 54% to 81% F1-score while maintaining strong cross-language generalization, with 9 of 10 languages achieving F1 above 0.80 under leave-one-language-out evaluation.

Index Terms—Credential Leakage Detection, Three-class Classification, CodeBERT, Cross-language Generalization, Software Vulnerability Detection

I. INTRODUCTION

Public repositories have become an integral part of modern software development. Platforms such as GitHub enable large-scale collaboration, continuous integration, and rapid iteration. As projects evolve through commits, forks, and dependencies, maintaining security becomes increasingly difficult. When repositories become public, one persistent problem is credential leakage, in which passwords, API keys, and secret tokens are embedded directly in source code [1], [2], creating opportunities for attackers to scan and harvest them.

The scale of this issue continues to grow. The GitGuardian 2025 State of Secrets Sprawl Report states that 23.8 million new secrets were exposed in public GitHub repositories during 2024, a 25% increase from the previous year [3]. The report estimates that remediation requires two person-hours per incident, resulting in approximately \$5.7 billion in global labor cost [3]. Exposed credentials often persist across commits and propagate through forks, increasing long-term maintenance effort. Real-world breaches illustrate the impact.

In the 2016 Uber incident, attackers used exposed GitHub credentials to access hardcoded Amazon Web Services (AWS) keys, ultimately compromising internal systems and exposing data from 57 million users [4].

In the literature, empirical studies confirm that credential leakage is widespread and persistent. Meli et al. report that hardcoded secrets frequently remain exposed long after disclosure [5]. Feng et al. show that over 82% of leaked passwords remain accessible for at least 16 days [1]. These findings highlight the urgent need for automated detection techniques that scale across diverse languages while remaining precise enough for real-world maintenance workflows.

Existing credential leakage detection (CLD) approaches fall into two broad categories. First, rule-based tools, such as Gitleaks [6] and TruffleHog [7], rely on regular expressions and entropy heuristics. Although efficient, they often suffer from low recall or excessive false positives [8]. Basak et al. report that even the best-performing configuration achieves 75% precision with only 36% recall [8]. Second, learning-based approaches attempt to improve robustness. PassFinder uses character-level convolutional neural networks (CNNs) trained on password corpora and code context and reports 81.54% precision and 80.51% recall across ten languages [1]. Large language models (LLMs) have also been explored for security analysis [9], [10]. However, their black-box behavior and deployment cost limit practical integration into continuous integration pipelines.

Existing methods for CLD face three major limitations in maintenance settings.

First, most approaches treat credential detection as a *binary task*. They force ambiguous cases into either genuine leaks or benign code. Placeholder values such as `API_KEY = 'your_api_key_here'` and weak test credentials such as `password = 12345` with `user = 'user1'` resemble real secrets but often pose minimal risk. Binary framing increases false positives, creates alert fatigue, and reduces developer trust [11], [12].

Second, many models rely on surface patterns without *reasoning/semantic understanding* about how strings function in context. For example, `secret = 'your-secret'` may

appear as a default configuration value in an Express.js session setup. A syntactic detector flags it as a leak because it associates a hardcoded string with a security field. In practice, it may be a placeholder. Effective detection requires understanding how the string interacts with the surrounding code and what security boundary it affects [5], [8].

Lastly, detection *performance varies across programming languages*. Differences in syntax, naming conventions, and string literals reduce generalization. Tools tuned for one language often degrade on others [1], [13]. As projects span multiple ecosystems, consistent cross-language performance becomes essential.

We address these limitations through a three-class formulation that models ambiguity explicitly and incorporates semantic reasoning over source code. Our goal is to improve triage precision while maintaining strong coverage of genuine leaks across languages. Our main **contributions** are as follows.

- 1) We introduce a three-class formulation that distinguishes (i) *No Leak Credentials*, (ii) *Genuine Credentials*, and (iii) *Placeholder (or Weak Credentials)*, reducing false positives while preserving recall.
- 2) We construct and release a manually annotated dataset of 9,426 snippets across ten programming languages with high inter-annotator agreement (Cohen’s $\kappa = 0.89$) on Zenodo (doi:10.5281/zenodo.18881159) to ensure reproducibility. Note that sensitive information has been sanitized to prevent exposure of credentials.
- 3) We demonstrate that semantic representations from CodeBERT enable effective classification across all three classes, including placeholder disambiguation and genuine credential leak detection. Character-level pattern modeling provides complementary coverage, and a lightweight language adapter improves performance across 8 of 10 languages.

We aim to address the following research questions (RQs):

RQ1: Dataset Quality and Reliability. To what extent can a manually annotated dataset reliably capture credential occurrences across multiple programming languages?

RQ2: Three-Class Effectiveness. How effectively does the proposed three-class formulation detect genuine credential leaks while distinguishing them from placeholder or weak credentials?

RQ3: Cross-Language Generalization. How well does the model generalize across programming languages, and what role does the language adapter play?

RQ4: Architectural Component Contributions. What is the contribution of each architectural component to overall detection performance?

RQ5: Comparison with State-of-the-Art Systems. How does the approach compare with state-of-the-art CLD systems under a unified three-class evaluation?

The remainder of the paper is organized as follows. Section II reviews related work. Section III describes dataset construction. Section IV presents the proposed approach. Section V details the experimental setup. Section VI reports re-

sults. Section VII discusses threats to validity, and Section VIII concludes the paper.

II. RELATED WORK

This section reviews previous work on empirical measurement, detection techniques, and foundational approaches to semantic code understanding.

A. Empirical Studies and Measurement

Large-scale studies show that hardcoded credentials frequently appear in public repositories and often remain valid long enough to pose serious risks. Meli et al. demonstrated that exposed secrets persist over time in GitHub repositories, creating opportunities for compromise [5], and related work confirms that security-sensitive hardcoded values remain prevalent in practice [14]. Although these studies establish the severity of secret leakage, they focus on ecosystem-level measurement and do not provide labeled datasets for training or evaluation.

Subsequent research shows that leaked credentials propagate through forks and dependencies, while attackers actively monitor repositories for new leaks [15]–[17]. Leakage extends beyond source code to container images and mobile applications [18], [19], and insecure infrastructure-as-code patterns recur across projects [14]. Despite broadening the understanding of credential exposure, these works largely adopt a binary notion of leakage and do not address ambiguity from placeholders.

B. Detection Systems and Techniques

Most credential detection tools treat the task as binary classification, labeling credential-like strings as genuine leaks or benign code [1], [5]–[12], [15]–[20]. However, real-world code includes ambiguous cases such as placeholders (e.g., `YOUR_API_KEY`) and weak credentials (e.g., `pwd = 'abcd'` with `user = 'dummy_user'`) that resemble real secrets but pose no actionable risk. Misclassification increases false positives and warning overload. Prior studies show that excessive false positives and poor prioritization reduce developer trust and long-term adoption [21]–[25]. These findings underscore the need to distinguish ambiguous credential-like strings while preserving actionable warnings.

Existing secret detection techniques are categorized into rule-based and learning-based approaches [8]. Rule-based methods rely on predefined patterns, whereas learning-based methods infer credential characteristics from data. We will discuss them in detail in the following paragraphs.

Rule-based secret detection systems rely on manually crafted patterns, regular expressions, and entropy-based heuristics to identify credential-like strings in source code [6], [7]. Although widely adopted, these rule-based approaches lack contextual reasoning, leading to precision below 75% in large-scale evaluations due to difficulty distinguishing placeholders from genuine credentials [8]. This limitation produces numerous false positives and low-value alerts, contributing to warning fatigue and reduced practical effectiveness.

Learning-based methods improve credential detection by modeling credential patterns from data through neural representations or contextual reasoning [20], such as PassFinder’s character-level representations [1] and secret–asset relationship modeling for contextual triage [26]. Although these methods outperform rule-based systems, they remain binary and do not model dataset or label-level ambiguity. Recent work also applies LLMs such as ChatGPT to security analysis [27], but deployment challenges—including high cost, latency, limited transparency [28], confidentiality concerns, and risks of insecure or over-trusted outputs [9], [10]—limit their practicality, motivating specialized models that better balance accuracy, efficiency, and interpretability.

A major barrier to advancing detection techniques is the lack of publicly available labeled datasets. Most measurement studies do not release annotated data for supervised learning [5], [15], and PassFinder did not publish its full annotated dataset due to security and privacy concerns [1]. Existing benchmarks such as CodeSearchNet and Vault support semantic code understanding but do not specifically address credential detection or distinguish genuine credential leaks from placeholders and benign code [29], [30]. This scarcity of annotated datasets limits the training, evaluation, and comparison of detection models under realistic conditions.

C. Foundations for Semantic and Cross-Language Detection

Semantic code representation models underpin credential detection, and surveys highlight their effectiveness for code intelligence tasks [13]. CodeBERT introduced joint pretraining on code and natural language [31], and GraphCodeBERT incorporated data-flow information to capture deeper semantics [32]. Models such as PLBART and UniXcoder further support cross-language understanding [33], [34]. Although these approaches improve tasks like defect prediction and code search [13], they are not designed to distinguish ambiguous credential-like strings from genuine secrets.

Cross-language detection is challenging due to syntactic and convention differences. PassFinder showed that performance varies significantly across languages despite shared character-level features [1]. Recent code representation models reduce such discrepancies through shared semantics and multilingual pretraining. CodeBERT [31], GraphCodeBERT [32], and UniXcoder [34] improve cross-language generalization, but they do not explicitly address ambiguity in credential detection.

In contrast to prior work, our approach formulates CLD as a three-class classification problem that distinguishes genuine credentials, placeholders, and benign code. We construct and release a manually annotated dataset to support reproducible evaluation. Our hybrid method leverages snippet-level semantic context to distinguish genuine leaks from placeholders, reducing alert fatigue while maintaining strong detection coverage, with character-level pattern recognition jointly capturing surface-level string characteristics. We further evaluate cross-language generalization across ten programming languages, demonstrating consistent performance despite syntactic di-

TABLE I
OVERALL CLASS DISTRIBUTION IN THE PROPOSED DATASET.

Class	Count	Proportion
No Leak(Class 0)	5,903	62.6%
Genuine Leak (Class 1)	2,363	25.1%
Placeholder(Class 2)	1,160	12.3%
Total	9,426	100%

versity. These contributions address key limitations of prior binary detection approaches and improve practical credential detection workflows.

III. DATASET CONSTRUCTION AND ANNOTATION

We build a manually annotated dataset to evaluate our CLD system. We collect credential-related code snippets from public GitHub repositories. The dataset supports the three-class formulation from Section I: (i) *No Leak*, (ii) *Genuine Credential Leak*, and (iii) *Placeholder*. This section describes the data collection process, candidate extraction strategy, annotation schema, annotation workflow, and dataset statistics.

A. Data Collection and Candidate Extraction

We collect candidate code snippets from public GitHub repositories using the GitHub REST API via the PyGithub client [35]. Following prior work, we harvest candidates through GitHub’s code search interface (rather than sampling repositories directly), as it scales to large corpora and better reflects how developers locate code in practice [36], [37]. Searches are scoped to 10 programming languages: C, C++, C#, Go, Java, JavaScript, PHP, Python, Ruby, and TypeScript using the `language` qualifier. These languages span diverse syntax styles, type systems, and paradigms, allowing us to assess whether the three-class formulation generalizes across heterogeneous development contexts [1], [13].

Search queries combine credential-related seed terms (`password`, `token`, `secret`, `api_key`) with contextual terms covering email domains, infrastructure identifiers (e.g., `host`, `database`), account-related terms (e.g., `login`, `authenticate`), and specific phrases such as `client_secret` and `basic authentication`. Queries are randomly shuffled before execution to improve diversity. This keyword strategy follows prior detection work and applies only to candidate collection, not to training or evaluation [1], [5], [8].

Snippets are deduplicated by hashing the context window. The collector targets up to 1,000 unique snippets per language, rotating across a pool of API tokens when the rate-limit quota falls below a safety threshold. Each snippet is stored with metadata including programming language, repository name, file path, GitHub URL, matched line, and collection timestamp; the `label` column is left empty for manual annotation, as described next.

TABLE II
PER-LANGUAGE AND PER-CLASS SAMPLE DISTRIBUTION IN THE PROPOSED DATASET.

Language	No Leak	Genuine Leak	Placeholder	Total
C	763 (86.8%)	58 (6.6%)	58 (6.6%)	879
C#	654 (69.2%)	218 (23.1%)	73 (7.7%)	945
C++	799 (83.7%)	95 (9.9%)	61 (6.4%)	955
Go	838 (88.0%)	72 (7.6%)	42 (4.4%)	952
Java	348 (36.7%)	385 (40.6%)	215 (22.7%)	948
JavaScript	332 (34.3%)	439 (45.4%)	196 (20.3%)	967
PHP	640 (66.3%)	229 (23.7%)	97 (10.0%)	966
Python	295 (30.7%)	503 (52.3%)	163 (17.0%)	961
Ruby	547 (60.6%)	198 (22.0%)	157 (17.4%)	902
TypeScript	687 (72.2%)	166 (17.5%)	98 (10.3%)	951
Total	5,903 (62.6%)	2,363 (25.1%)	1,160 (12.3%)	9,426

B. Annotation Schema

Existing binary formulations fail to distinguish genuine credentials from placeholder values, producing large volumes of false alerts in practice [8], [21], [24], [25]. We propose a three-class schema that explicitly models this ambiguity. Each candidate snippet is assigned one label based on its security significance and likelihood of enabling unauthorized access:

- **No Leak (Class 0):** No literal credential value is present. Includes indirect references, environment-variable lookups, schema definitions, and external configuration retrieval. Typical examples: `api_key = os.getenv("API_KEY"), config["secret"] = get_secret("DB_PASSWORD"), class User: password: str.`
- **Genuine Credential Leak (Class 1):** A hardcoded value that appears to represent a valid authentication secret within the code context. It covers human- or machine-generated passwords, API keys, secret tokens, and client secrets (e.g., `password="to*****08", api_key="AIzaSyD*****mE"`).¹ Weak passwords paired with realistic usernames or email addresses also fall into this class, as the combination carries real access risk even when the password itself seems weak (e.g., `user="m****@outlook.com"; pwd="abc123"`).
- **Placeholder (Class 2):** The value resembles a credential syntactically but clearly serves as a placeholder, example, or test artifact. This includes explicit placeholder indicators (e.g., `password="Your_Pwd_Here"` with `user="dummy_user"`), and trivial credential pairs used for testing (e.g., `password="12345"` with `user="user1"`). Because such values follow the same syntactic patterns as real credentials (e.g., `password=...` or `token=...`), they are often captured during candidate extraction but can be distinguished through contextual cues indicating documentation, examples, or test configurations rather than deployable authentication secrets.

Since intent depends on context, identical strings may receive different labels depending on whether they appear in

production paths, test fixtures, or documentation, reflecting ambiguity common in public repositories [8].

Annotation Decision Strategy: Special attention is given to weak passwords that, when paired with realistic usernames or emails (e.g., `user="dan****@gmail.com"; pwd="abcd"`), are treated as Class 1 due to their potential for unauthorized access if deployed in real systems. However, when the username appears synthetic or generic (e.g., `user="dummy_user1"; pwd="abcd"`), the snippet is treated as Class 2, as the combination suggests a placeholder rather than a real credential.

C. Annotation Workflow and Quality Control

At least three co-authors annotate the dataset and cross-examine the annotations. Two primary annotators label each sample, and a third annotator independently reviews the assigned label. We measure inter-annotator agreement on a randomly sampled subset of 4,000 snippets from the full 9,426-sample dataset using Cohen’s κ and obtain a value of 0.89, indicating near-perfect agreement [38]. After agreement assessment, the third annotator reviews all disagreement cases and performs a final adjudication pass, resolving conflicts, enforcing consistent application of the labeling guidelines across programming languages, and correcting systematic inconsistencies (e.g., ensuring weak passwords are treated consistently when paired with realistic identifiers). The final dataset labels reflect this adjudicated outcome and serve as ground truth for all subsequent experiments.

D. Dataset Statistics and Availability

Table I summarizes the overall class distribution where genuine leaks account for 25.1% of samples and placeholders for 12.3%, reflecting the natural skew seen in real-world repositories. Table II further breaks down each class by programming language. Notably, languages commonly used for scripting and web development, such as Python, JavaScript, and Java exhibit, higher proportions of genuine leaks and placeholders, consistent with their prevalence in public repositories and tutorial code. We include this breakdown to demonstrate that credential ambiguity is not confined to any single language

¹In all examples in this paper, we mask sensitive substrings using * to prevent exposing real credentials and to protect security and privacy.

but arises across heterogeneous codebases, motivating a three-class formulation that generalizes across development contexts.

IV. PROPOSED APPROACH

Figure 1 provides an overview of the model architecture and information flow. A code snippet is processed through two parallel streams: (i) a CharCNN encoder analyzing the candidate string at the character level and (ii) a CodeBERT encoder modeling the surrounding code context, whose outputs are fused, refined by a language adapter, and passed to a classifier to predict one of three credential classes: No Leak, Genuine Leak, or Placeholder.

We use a dual-stream architecture that combines syntactic and semantic cues. In the syntactic stream, we analyze the candidate string at the character level by embedding individual characters and applying convolutional filters of different sizes. This design allows us to capture both short and long character sequences, such as delimiters, structured prefixes, and fixed-length tokens, as character-level convolutional models are known to learn these structural patterns effectively across diverse formats [39].

The second stream models the semantic code context surrounding the candidate string. We encode the enclosing code snippet using a pretrained CodeBERT model, which jointly represents source code and natural language comments [31]. This representation captures contextual cues such as variable naming, assignment structure, and usage patterns that indicate whether a value serves as a real credential, a placeholder, or a benign constant. Semantic context plays a critical role in disambiguating cases where syntactic appearance alone is insufficient, such as enum values or documentation examples discussed in Section III.

We project the outputs of the two streams into a shared latent space and concatenate them to form a unified representation. A lightweight language adapter refines this representation using a feed-forward transformation with normalization and dropout. The adapter reduces language-specific variation while preserving signals relevant to credential semantics, supporting robustness across heterogeneous codebases without introducing language-specific modeling as a primary objective. A multi-layer perceptron classifier produces logits over the three credential classes. By combining these two streams within a three-class formulation, the proposed approach reduces alert noise and supports more effective triage in real-world software maintenance settings.

V. EXPERIMENTAL SETUP

This section describes the experimental protocol used to evaluate the proposed CLD approach. The baseline implementations and adaptations, evaluation metrics, and training configuration are described in the following subsections.

A. Datasets and Splits

To ensure consistency across methods and enable fair comparison, we construct a single stratified 80/10/10 split into

training, validation, and test sets using a fixed random seed over the same dataset (as described in Section III). We perform stratification jointly over class labels and programming languages to preserve both class balance and language diversity in each partition. We keep this data split fixed for all baselines and for our method.

To account for optimization variance, we train the proposed method using four different random initialization seeds (i.e., 42, 123, 456, and 789) while keeping the data partition unchanged. We report the mean and standard deviation across these runs. We use the validation set exclusively for hyperparameter tuning and early stopping, and we hold out the test set strictly for final evaluation.

B. Baseline Methods

We compare our approach against two state-of-the-art learning-based CLD systems. Since both prior works are originally designed for binary detection settings, we adapt them to support three-class snippet-level classification. To ensure fair comparison, we train all baselines with the same loss function, class weighting, and data split as our proposed method (described in Section V-C). Any performance difference therefore reflects architectural choices rather than training strategies.

PassFinder (Adapted). We adapt only the context model from PassFinder [1], which detects hard-coded passwords through character-level convolutional neural networks. The original architecture consists of a 6-layer character-level CNN with 256 filters per layer. To align PassFinder with our task formulation, we expand the output layer from binary (leak/no-leak) to a three-class classification. We maintain all other architectural components, including the original convolutional layer configuration (kernel sizes are 7, 3, 3, 3, 3, and 3), max pooling strategy, and fully connected layers with 50% dropout.

KEYSENTINEL (Adapted). We also compare against KEYSSENTINEL [15], the state-of-the-art CLD method. KEYSSENTINEL extracts credential candidates using 910 regex patterns, applies a six-stage heuristic filtering pipeline (T1 through T6), and classifies candidates with a character-level TextCNN. Because snippets provide less context than complete files, we adjust KEYSSENTINEL’s filter thresholds. We lower T1’s minimum length from 6 to 4 characters, reduce T3’s entropy thresholds from 2.4/3.0 to 2.0/2.5, and relax T4’s word ratio threshold from 35% to 50%. We retrain the TextCNN classifier on candidate strings extracted from our labeled snippets using three-way classification. To produce snippet-level predictions, KEYSSENTINEL aggregates its candidate-level outputs. The method labels a snippet as *Genuine Leak* when any candidate exceeds confidence threshold $\tau = 0.50$ or matches definitive patterns like AWS keys, JWTs, or Privacy-Enhanced Mail (PEM) blocks. Otherwise, KEYSSENTINEL assigns *Placeholder* when it detects placeholder markers ($\tau = 0.60$), or *No Leak* when neither condition holds.

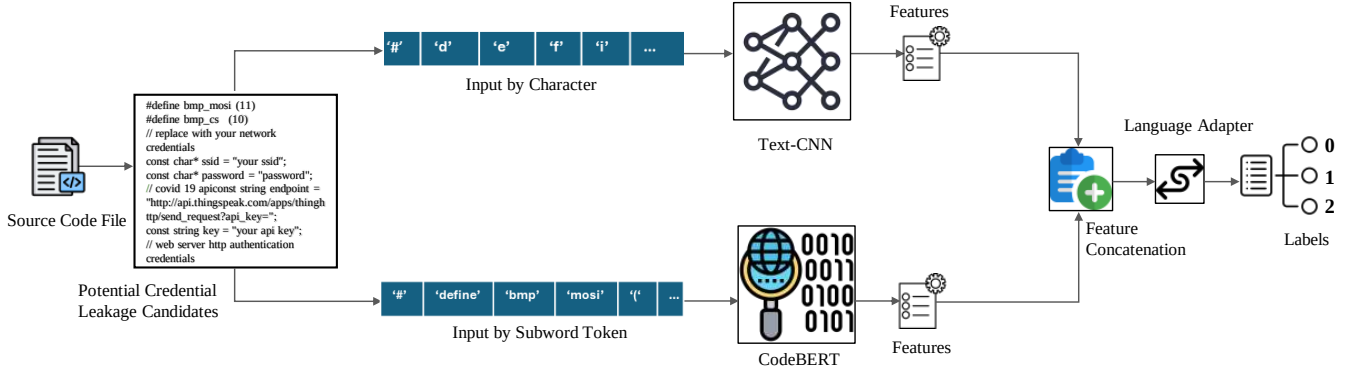


Fig. 1. Overview of the proposed hybrid credential leakage detection model. A CodeBERT-based semantic encoder models surrounding code context to classify across all three classes: 0 (No Leak), 1 (Genuine Leak), and 2 (Placeholder), with a character-level encoder providing complementary syntactic coverage. The fused representation is refined by a language adapter and classifier to produce the final prediction.

C. Training and Implementation Details

All models are implemented in PyTorch and trained on a single NVIDIA GPU. Our hybrid architecture combines a character-level CNN encoder ($d_c = 32$, 32 filters per kernel size in $\{3, 5, 7\}$, up to 800 characters) with CodeBERT-base [31] for semantic understanding (up to 256 tokens), with the first 6 layers frozen. Both encoders project to 384-dimensional representations before concatenation. The language adapter reduces the 768-dimensional fused space to 384 via a feed-forward network with ReLU, dropout, and layer normalization. The final classifier uses two fully connected layers ($384 \times 96 \times 3$) with dropout 0.2.

To address class imbalance, we employ focal loss [40] ($\gamma = 2.0$) with inverse square-root class weighting. We use AdamW (weight decay 0.01, gradient clipping 1.0) with differentiated learning rates: 3×10^{-5} for non-CodeBERT and 6×10^{-6} for CodeBERT layers, with a linear decay scheduler to 10%. Training runs for 15 epochs maximum with early stopping (patience = 5) on validation Matthews Correlation Coefficient (MCC) and batch size 32.

VI. RESULTS AND ANALYSIS

We present a comprehensive evaluation of the proposed CLD approach organized around the five research questions stated in Section I. We report Seed 42 results as our primary evaluation unless otherwise stated; mean and standard deviation over four seeds (42, 123, 456, and 789) are reported to demonstrate robustness.

A. RQ1: Dataset Quality and Reliability

To what extent can a manually annotated dataset reliably capture credential occurrences across multiple programming languages?

Two annotators label each sample independently and achieve Cohen’s $\kappa = 0.89$ before adjudication, which indicates

TABLE III
PER-CLASS PERFORMANCE OF THE PROPOSED METHOD UNDER SEED 42.

Class	Precision	Recall	F1
No Leak	0.96	0.93	0.95
Genuine Leak	0.89	0.93	0.91
Placeholder	0.78	0.83	0.81

near-perfect agreement [38]. This level of agreement is meaningful because the task is inherently difficult. Many credential-like strings look structurally similar, and correct labeling often requires reasoning about the surrounding code context rather than the string value alone. The three-class schema proves consistently interpretable across annotators, which confirms that security practitioners can reliably distinguish genuine leaks from placeholders.

All 10 languages contribute balanced test samples (88–97 instances each), and all 3 classes appear in every language. This confirms that placeholders are not specific to any single language but arise consistently across heterogeneous codebases.

RQ1 Summary: The dataset reliably captures credential occurrences across 10 programming languages with near-perfect inter-annotator agreement ($\kappa = 0.89$), providing a balanced and representative foundation for evaluating the three-class credential detection.

B. RQ2: Three-Class Detection Effectiveness

How effectively does the proposed three-class formulation detect genuine credential leaks while distinguishing them from placeholder or weak credentials?

1) *Per-Class Performance:* In Table III the model reports F1 of 0.95 for No Leak, 0.91 for Genuine Credential Leak,

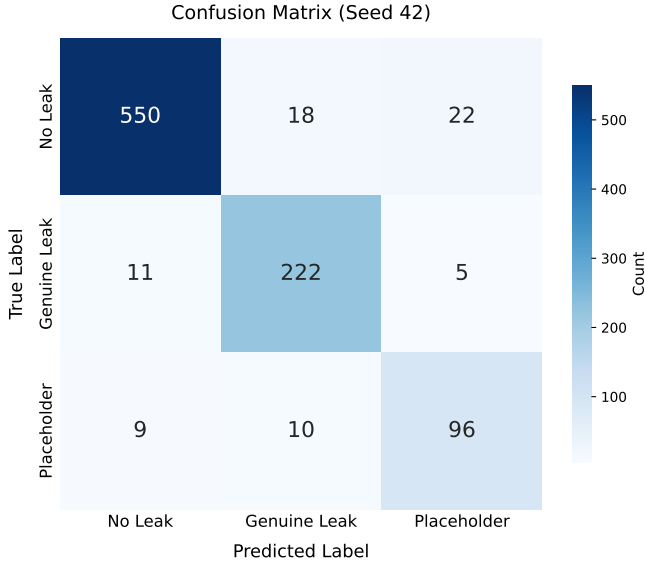


Fig. 2. Confusion matrix of the proposed model under Seed 42. Out of 943 test samples, 868 are correctly classified.

and 0.81 for Placeholder. The Genuine Leak recall of 0.93 is the most security-critical metric, where the model correctly identifies 222 out of 238 test cases, missing only 16 actual credentials. Placeholder detection shows higher recall (0.83) than precision (0.78), reflecting a conservative design choice where the model prefers to flag ambiguous strings as placeholders rather than risk misclassifying them as genuine threats.

Table IV confirms these results hold consistently across all four seeds. Per-class performance remains stable across initializations: No Leak F1 at 0.95 ± 0.002 , Genuine Leak F1 at 0.90 ± 0.004 , and Placeholder F1 at 0.80 ± 0.008 , confirming consistent learning regardless of initialization. The only moderate variance appears in placeholder precision (0.76 ± 0.020), reflecting the inherent ambiguity of borderline cases that shift slightly across initializations.

2) *Error Analysis*: Figure 2 shows the confusion matrix. Out of 943 test samples, the model misclassifies 75 cases (8.0%). Three dominant error patterns emerge. The most frequent errors involve No Leak misclassification: 18 samples are predicted as Genuine Leak and 22 as Placeholder. These arise when variable names carry strong credential signals (e.g., `password`, `api_key`) even though no literal value is assigned. In such cases, the character-level encoder responds to the variable name rather than the absent value.

The most security-critical errors are five cases where the model predicts Placeholder instead of Genuine Leak. These involve weak, dictionary-like passwords (e.g., `"root"`, `"password"`) in low-specificity contexts that resemble test fixtures. JavaScript contributes two of these five cases, where test scaffolding and production code often share identical credential patterns.

Finally, 10 Placeholder samples are incorrectly flagged as Genuine Leaks. These involve test configurations where

TABLE IV
PER-CLASS PERFORMANCE OF THE PROPOSED METHOD ACROSS FOUR RANDOM SEEDS (MEAN $\pm$ STD).

Class	Metric	Mean $\pm$ Std
No Leak	Precision	0.97 ± 0.004
	Recall	0.93 ± 0.005
	F1	0.95 ± 0.002
	MCC	0.87 ± 0.006
Genuine Leak	Precision	0.88 ± 0.006
	Recall	0.93 ± 0.009
	F1	0.90 ± 0.004
	MCC	0.87 ± 0.005
Placeholder	Precision	0.76 ± 0.020
	Recall	0.84 ± 0.007
	F1	0.80 ± 0.008
	MCC	0.77 ± 0.009

placeholder strings lack explicit syntactic markers. For instance, a C# server configuration contains `Password = "youshallnotpass"`. This is a reference to the movie *The Lord of the Rings* and is clearly a placeholder, not a real credential. However, the model flags it as genuine because the string lacks conventional placeholder markers such as underscores or capitalized instruction text like `YOUR_PASSWORD`. Without explicit markers or surrounding comments indicating test usage, the model sometimes misinterprets creative placeholder text as potentially real credentials. Java and C# together account for 4 of these 10 cases.

Impact on Alert Triage. Binary credential detectors produce only two outcomes (alert vs. no alert) and therefore cannot differentiate between genuine leaks and placeholder artifacts; as a result, both are surfaced as alerts requiring manual inspection. To quantify this maintenance impact, we simulate a binary alerting view in which any credential-like prediction (Genuine or Placeholder) is surfaced as an alert. On the test set, this yields 373 alerts. In contrast, our three-class model distinguishes placeholders from genuine leaks and produces 250 high-severity alerts (predicted Genuine only), corresponding to a 33.0% reduction in high-severity alerts while maintaining 93% recall for genuine leaks.

RQ2 Summary: The three-class formulation effectively detects genuine leaks (recall: 0.93, F1: 0.91) while distinguishing placeholders (F1: 0.81), achieving overall model Macro-F1 of 0.90 and MCC of 0.86. This reduces high-severity alert volume by 33.0% (373 $\rightarrow$ 250) without sacrificing security coverage.

C. RQ3: Cross-Language Generalization

How well does the approach generalize across programming languages, and what role does the language adapter play?

TABLE V
LOLO CROSS-VALIDATION RESULTS. MODEL TRAINED ON NINE
LANGUAGES, EVALUATED ON AN UNSEEN TARGET LANGUAGE.

Language	Prec	Rec	F1	MCC
C	0.87	0.91	0.89	0.85
C#	0.79	0.89	0.82	0.80
C++	0.80	0.88	0.84	0.80
Go	0.75	0.78	0.76	0.72
Java	0.89	0.88	0.89	0.84
JavaScript	0.83	0.85	0.84	0.78
PHP	0.82	0.86	0.83	0.78
Python	0.86	0.85	0.85	0.78
Ruby	0.82	0.86	0.83	0.78
TypeScript	0.76	0.85	0.80	0.74
Average	0.81	0.86	0.83	0.79

TABLE VI
PER-LANGUAGE MCC: FULL MODEL VS. NO ADAPTER (SEED 42).
BLUE/RED Δ MCC INDICATES GAIN/LOSS FROM THE ADAPTER.

Language	MCC _{Full}	MCC _{NoAdp}	Δ MCC
C	82.9	79.6	+3.3
C#	91.6	89.2	+2.4
C++	79.8	76.5	+3.3
Go	75.5	75.5	0.0
Java	85.5	82.2	+3.3
JavaScript	88.5	80.8	+7.7
PHP	83.0	87.6	-4.6
Python	77.5	77.7	-0.2
Ruby	92.6	90.9	+1.7
TypeScript	82.0	80.1	+1.9

All values in %. Δ MCC = MCC_{Full} minus MCC_{NoAdp}.

1) *Leave-One-Language-Out Cross-Validation*: To assess cross-language generalization, we conduct Leave-One-Language-Out (LOLO) cross-validation, where we train on nine languages and evaluate on the held-out language. This protocol tests whether the model can generalize to entirely unseen programming languages without any language-specific training data.

Table V shows LOLO results. The model achieves an average F1 of 0.83 and MCC of 0.79 across all 10 languages, demonstrating robust generalization to completely unseen languages. Performance remains strong even without language-specific training data, with 9 languages achieving $F_1 \geq 0.80$. C, Java, and Python show particularly strong LOLO performance ($F_1 \geq 0.85$), while Go and TypeScript show slightly lower but still reasonable performance (F_1 : 0.76, 0.80, respectively). The consistent performance across diverse language families confirms that the model learns language-invariant credential patterns rather than overfitting to language-specific syntax.

2) *Impact of Language Adapter*: Having established a strong baseline cross-language generalization, we now examine whether the language adapter further improves performance. Table VI compares the full model with the no-adapter variant across all 10 languages.

The language adapter provides consistent benefits across 8 of 10 languages. JavaScript achieves the largest gain, i.e., 7.7 percentage points (pp) increase in MCC, suggesting the adapter effectively handles its loosely-typed variable patterns, dynamic string construction, and diverse credential assignment idioms. For C, Java, and C++, all of them show moderate improvements (+3.3 pp), indicating that the adapter captures useful syntactic signals even in statically-typed languages where credential patterns are more rigidly structured. C# (+2.4 pp), TypeScript (+1.9 pp), and Ruby (+1.7 pp) show smaller but consistent gains, while Go exhibits a neutral effect (0.0 pp).

Two languages show degradation: PHP (−4.6 pp) and Python (−0.2 pp). PHP’s decline suggests that language-specific conditioning may introduce noise when the adapter’s learned representation conflicts with PHP’s weakly-typed string interpolation and mixed quoting conventions. Python’s drop of 0.2 pp is negligible and falls within the expected single-seed variance, effectively constituting a neutral result.

Overall, the adapter improves or preserves performance for 9 of 10 languages, with the single meaningful degradation isolated to PHP. This pattern indicates that language-specific conditioning is broadly beneficial across diverse language families, particularly for languages with heterogeneous string handling and dynamic typing with PHP standing as a notable exception warranting further investigation.

RQ3 Summary: The model demonstrates robust cross-language generalization through LOLO evaluation (average F_1 : 0.83, MCC: 0.79), with 9 languages achieving $F_1 \geq 0.80$ even when completely unseen during training. The language adapter provides consistent gains across 8 of 10 languages, with JavaScript benefiting the most (+7.7 pp MCC). PHP is the primary exception (−4.6 pp), while Python shows a negligible neutral effect (−0.2 pp), indicating broadly beneficial but not universal adaptation.

D. RQ4: Architectural Component Contributions

What is the contribution of each architectural component to overall detection performance?

Table VII presents a comprehensive ablation study in which we systematically isolate the contribution of each component. We evaluate six variants to understand both individual and combined effects of the character-level encoder, semantic encoder, and language adapter.

The semantic code encoder (CodeBERT) is the dominant component. Removing it causes performance to drop substantially (MCC: 0.86 $\rightarrow$ 0.57, F1: 0.90 $\rightarrow$ 0.67), demonstrating that understanding surrounding code context is essential for distinguishing placeholders from genuine credentials. The CodeBERT-only variant achieves an MCC of 0.85, and the full model improves upon this by 1.0 pp (0.85 $\rightarrow$ 0.86), indicating

TABLE VII
ABLATION STUDY SHOWING COMPONENT CONTRIBUTIONS (SEED 42).
FULL MODEL USES CHARCNN+CODEBERT+ADAPTER; OTHER
VARIANTS ISOLATE INDIVIDUAL COMPONENTS AND COMBINATIONS.

Variant	MCC	F1	Prec	Rec
Full Model	0.86	0.90	0.89	0.91
CharCNN Only	0.62	0.70	0.68	0.72
CharCNN + Adapter	0.57	0.67	0.66	0.70
CodeBERT Only	0.85	0.88	0.86	0.90
CodeBERT + Adapter	0.85	0.88	0.87	0.90
No Adapter	0.85	0.88	0.87	0.90

that character-level features provide a complementary signal beyond what semantic context alone captures.

We retain the character-level encoder for two reasons. First, character patterns provide targeted coverage for highly structured credentials—such as AWS access keys (fixed 20-character alphanumeric format), JWTs (three dot-delimited Base64 segments), and PEM-encoded private keys (structured header/footer delimiters)—that follow rigid surface formats, which CodeBERT’s subword tokenization may not preserve faithfully. Second, the computational overhead is negligible (32 filters vs. CodeBERT’s 768-dimensional embeddings), making retention a low-cost robustness measure for deployment scenarios where such structured tokens appear outside the training distribution.

The language adapter yields a 1.0 pp aggregate MCC gain (0.85 $\rightarrow$ 0.86), with the largest benefit for JavaScript (+7.7 pp) and consistent moderate gains for C, Java, and C++ (+3.3 pp each). PHP is the primary exception (−4.6 pp), and Python shows a negligible neutral effect (−0.2 pp). Practitioners working primarily in PHP may prefer the no-adapter variant.

RQ4 Summary: The semantic code encoder is the critical component (MCC reduces by 29.0 pp when it is removed). The three-class formulation is primarily enabled by CodeBERT’s contextual understanding, while character-level features provide targeted complementary coverage for structurally rigid credential formats such as AWS keys and JWTs that undergo subword tokenization may be fragmented. The full model improves upon CodeBERT-only by 1.0 pp MCC at negligible computational cost. The language adapter contributes further 1.0 pp aggregate gain, improving performance across 8 of 10 languages, with mixed effects for PHP and Python as detailed in RQ3.

E. RQ5: Comparison with State-of-the-Art Systems

How does the proposed approach compare with state-of-the-art CLD systems under a unified three-class evaluation?

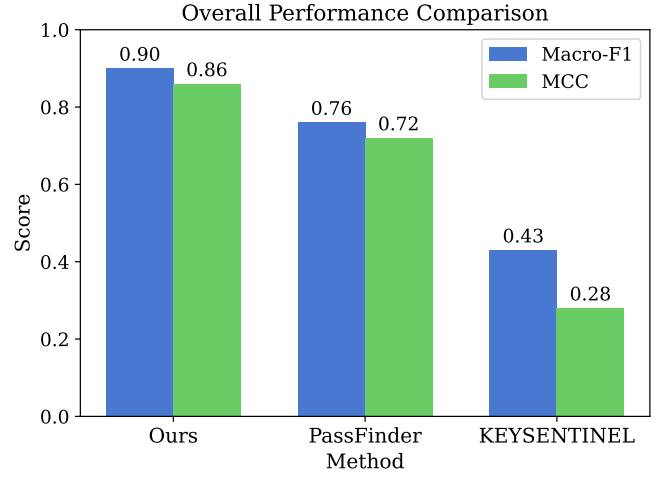


Fig. 3. Overall performance comparison across methods. Our approach substantially outperforms both baselines in Macro-F1 and MCC.

TABLE VIII
PER-CLASS PERFORMANCE COMPARISON ACROSS THREE METHODS
(SEED 42). PF = PASSFINDER; KS = KEYSENTINEL.

Class	Metric	Ours	PF	KS
No Leak	Precision	0.96	0.96	0.67
	Recall	0.93	0.93	0.94
	F1	0.95	0.93	0.78
Genuine Leak	Precision	0.89	0.84	0.94
	Recall	0.93	0.79	0.30
	F1	0.91	0.81	0.46
Placeholder	Precision	0.78	0.50	0.09
	Recall	0.83	0.58	0.03
	F1	0.81	0.54	0.04

Figure 3 and Table VIII present comprehensive comparisons between our approach and two state-of-the-art learning-based credential detection systems adapted to the three-class setting.

1) *Comparison with PassFinder:* PassFinder relies primarily on character-level patterns with limited semantic context modeling, restricting its ability to resolve ambiguous credential-like strings. Our approach improves overall Macro-F1 and MCC by 14.0 pp each (0.76 $\rightarrow$ 0.90 and 0.72 $\rightarrow$ 0.86, respectively). The most significant improvement occurs in the placeholder class, where our F1 score of 0.81 exceeds PassFinder’s 0.54 by 27.0 pp. This supports our hypothesis that combining semantic code context with character-level features improves disambiguation of placeholders that resemble genuine secrets at the surface level but differ in their contextual usage.

For genuine credential detection, our approach also improves over PassFinder (F1: 0.91 vs. 0.81), driven by higher recall (0.93 vs. 0.79). This improvement stems from semantic understanding of credential usage patterns, enabling detection of low-entropy human-chosen passwords that lack distinctive character patterns but appear in security-relevant contexts.

2) *Comparison with KEYSENTINEL*: KEYSENTINEL was originally designed for file-level detection. Our evaluation adapts it to snippet-level classification to assess architectural trade-offs under a unified setting. It achieves Macro-F1 of 0.43 and MCC of 0.28 in our snippet-level evaluation. The results reveal an important finding about heuristic filtering approaches. The genuine leak recall of 0.30 indicates that extensive filtering designed to reduce false positives in file-level detection inadvertently discards 70% of real credentials when applied to limited-context snippets. This demonstrates a fundamental trade-off in context-discarding paradigms: aggressive filtering that works well for cross-platform file-level detection (KEYSENTINEL’s core contribution) becomes overly restrictive when context is limited.

Placeholder detection fails almost completely (F1: 0.04, recall: 0.03) because low-entropy placeholder strings (e.g., "YOUR_API_KEY", "dummy_token") fail T3 entropy filters, while word-heavy placeholders fail T4 semantic filters. Both filter stages were designed to remove non-credentials, but cannot distinguish intentional placeholders from weak credentials without surrounding code context.

These results highlight complementary strengths: KEYSENTINEL’s cross-platform filtering excels in file-level detection, where broader context supports candidate retention, while our context-preserving semantic approach better handles snippet-level scenarios common in code review and pull request workflows.

3) *Three-Class Detection Value*: The substantial improvements in placeholder identification (F1: 0.81 vs. baseline range 0.04-0.54) demonstrate clear practical value of explicit three-class formulation. In deployment scenarios, flagging placeholders as a separate category enables developers to triage alerts more effectively, reducing alert fatigue without sacrificing security coverage. The high recall for genuine leaks (0.93) ensures that critical security threats are rarely missed despite the additional class complexity.

RQ5 Summary: The proposed approach substantially outperforms adapted baselines. Compared to PassFinder, we improve Macro-F1 by 14.0 pp and placeholder detection by 27.0 pp. KEYSENTINEL’s low snippet-level performance (30% genuine leak recall) reveals that aggressive heuristic filtering designed for file-level detection inadvertently discards real credentials when context is limited, demonstrating complementary strengths: cross-platform filtering for files versus semantic context preservation for snippets.

VII. THREATS TO VALIDITY

Construct Validity. Labeling credential data involves judgment, particularly for borderline placeholder cases. We mitigate this using a three-stage annotation workflow with near-perfect inter-annotator agreement (Cohen’s $\kappa = 0.89$), where genuinely ambiguous cases are conservatively assigned to the Genuine Leak class to minimize underestimation of security

impact. The binary alert simulation in RQ2 surfaces both Genuine and Placeholder predictions as undifferentiated alerts, reflecting how a two-class system behaves without reinterpreting placeholder labels.

Internal Validity. All methods use identical data splits, training procedures, and evaluation protocols. Results are reported across four random seeds to account for initialization variance. Hyperparameters were tuned exclusively on the validation set with a strict test set holdout.

External Validity. Evaluation spans 10 programming languages and public repositories. Results may not fully generalize to proprietary or highly obfuscated code. The reported 33.0% alert reduction reflects test-set class proportions; actual reduction in deployment will vary with repository-level placeholder rates. However, Leave-One-Language-Out validation (average F1: 0.83; all languages F1 ≥ 0.76) indicates that the model captures language-invariant credential patterns. Snippet-level evaluation (up to 13 lines) reflects realistic review settings but excludes repository-level context.

Baseline Adaptation. PassFinder and KEYSENTINEL were adapted for three-class, snippet-level classification while preserving core architectures. Both were trained under identical settings for fairness. Lower snippet-level recall (e.g., 30% for KEYSENTINEL) likely reflects adaptation to a finer-grained task rather than inherent method weakness, highlighting trade-offs in context-dependent approaches.

VIII. CONCLUSION AND FUTURE WORK

This paper introduces a three-class formulation for CLD that explicitly separates genuine credential leaks, placeholders, and benign code. Evaluation on 9,426 manually annotated snippets across 10 programming languages demonstrates strong performance (Macro-F1: 0.90, MCC: 0.86, Genuine Leak recall: 0.93) with robust cross-language generalization (LOLO average F1: 0.83), reducing high-severity alerts by 33.0% without sacrificing security coverage. Compared to prior character-level methods, placeholder detection improves from 54% to 81% F1-score. Ablation studies confirm semantic code understanding as the critical component, with character-level features providing complementary coverage and the language adapter, improving 8 of 10 programming languages.

Future work includes, but is not limited to: (i) incorporating repository-level context (e.g., dependency structure and version history) to improve disambiguation, (ii) extending detection beyond source code to non-code artifacts where credentials commonly appear (e.g., configuration files and documentation), and (iii) investigating LLM-based augmentation to better handle hard borderline cases, e.g., via active learning with LLM-assisted annotation and targeted synthesis of ambiguous placeholders. In addition, we plan to conduct user studies to assess whether multi-class triage reduces alert fatigue in practice, and to explore lightweight deployment variants suitable for continuous integration.

DATA AVAILABILITY

The artifacts, including source code and sanitized datasets, are publicly available at Zenodo

(doi:10.5281/zenodo.18881159). Due to security and privacy concerns, only the Class 0 (No Leak) samples are released publicly, as Classes 1 and 2 contain credential-like strings that could expose sensitive patterns if made openly available.

ACKNOWLEDGMENT

This work was supported in part by the National Science Foundation under Grant No. 2347249. The authors would also like to thank Poorva Shetye for her assistance with the initial data collection.

REFERENCES

- [1] R. Feng *et al.*, “Automated detection of password leakage from public github repositories,” in *Proceedings of the International Conference on Software Engineering (ICSE)*, pp. 175–186, 2022.
- [2] M. N. Rahman, S. Ahmed, Z. Wahab, G. Uddin, and R. Shahriyar, “IssueGuard: Real-time secret leak prevention tool for GitHub issue reports,” *arXiv preprint arXiv:2602.08072*, 2026.
- [3] GitGuardian, “State of secrets sprawl 2025: The definitive annual report on the state of secrets exposure on github,” tech. rep., GitGuardian, March 2025.
- [4] Uber Technologies Inc., “Information about 2016 data security incident,” 2016.
- [5] M. Meli *et al.*, “How bad can it get? characterizing secret leakage in public github repositories,” in *Proceedings of the Network and Distributed System Security Symposium (NDSS)*, 2019.
- [6] Gitleaks Project, “Gitleaks: Detecting hardcoded secrets using pattern matching and entropy analysis.” <https://github.com/gitleaks/gitleaks>, 2024.
- [7] Truffle Security, “TruffleHog: Searching for high-entropy strings and secrets in git repositories.” <https://github.com/trufflesecurity/trufflehog>, 2024.
- [8] S. K. Basak *et al.*, “A comparative study of software secrets reporting by secret detection tools,” in *Proceedings of ESEM*, pp. 1–12, 2023.
- [9] A. Pearce, L. Li, and K. Sen, “Asleep at the keyboard? assessing the security of ai-generated code,” in *Proc. of the IEEE Symposium on Security and Privacy*, pp. 765–783, 2022.
- [10] G. Sandoval, H. Pearce, T. Nys, R. Karri, S. Garg, and B. Dolan-Gavitt, “Lost at c: A user study on the security implications of large language model code assistants,” in *32nd USENIX Security Symposium (USENIX Security 23)*, pp. 2205–2222, 2023.
- [11] B. Chess and G. McGraw, “Static analysis for security,” *IEEE Security & Privacy*, vol. 2, no. 6, pp. 76–79, 2004.
- [12] M. R. Rahman *et al.*, “Why secret detection tools are not enough: An industrial case study,” *Empirical Software Engineering*, vol. 27, no. 3, pp. 1–29, 2022.
- [13] M. Allamanis, E. T. Barr, P. Devanbu, and C. Sutton, “A survey of machine learning for big code and naturalness,” *ACM Computing Surveys*, vol. 51, no. 4, pp. 1–37, 2018.
- [14] A. Rahman, C. Parnin, and L. Williams, “The seven sins: Security smells in infrastructure as code scripts,” in *2019 IEEE/ACM 41st International Conference on Software Engineering (ICSE)*, pp. 164–175, IEEE, 2019.
- [15] J. Zhou *et al.*, “Hey, your secrets leaked! detecting and characterizing secret leakage in the wild,” in *Proceedings of the IEEE Symposium on Security and Privacy (SP)*, pp. 449–467, 2025.
- [16] Y. Zhang, Y. Yang, and Z. Lin, “Don’t leak your keys: Understanding, measuring, and exploiting the appsecret leaks in mini-programs,” in *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*, pp. 2411–2425, 2023.
- [17] Y. Shi, G. Yang, Z. Yang, Y. Yang, M. Yang, K. Zhong, and X. Zhang, “The skeleton keys: A large-scale analysis of credential leakage in mini-apps,” in *Proceedings of the Network and Distributed System Security Symposium (NDSS)*, (San Diego, CA, USA), Internet Society, 2025.
- [18] M. Dahlmans, C. Sander, R. Decker, and K. Wehrle, “Secrets revealed in container images: an internet-wide study on occurrence and impact,” in *Proceedings of the 2023 ACM Asia Conference on Computer and Communications Security*, pp. 797–811, 2023.
- [19] D. Schmidt, S. Schrittwieser, and E. Weippl, “Leaky apps: Large-scale analysis of secrets distributed in android and ios apps,” in *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*, pp. 2459–2473, 2025.
- [20] A. Saha *et al.*, “Secrets in source code: Reducing false positives using machine learning,” in *Proceedings of COMSNETS*, pp. 168–175, 2020.
- [21] B. Johnson, Y. Song, E. Murphy-Hill, and R. Bowdidge, “Why don’t software developers use static analysis tools to find bugs?,” in *2013 35th International Conference on Software Engineering (ICSE)*, pp. 672–681, IEEE, 2013.
- [22] N. Ayewah, W. Pugh, J. D. Morgenthaler, J. Penix, and Y. Zhou, “Evaluating static analysis defect warnings on production software,” in *Proceedings of the 7th ACM SIGPLAN-SIGSOFT workshop on Program analysis for software tools and engineering*, pp. 1–8, 2007.
- [23] N. Ayewah, W. Pugh, D. Hovemeyer, J. D. Morgenthaler, and J. Penix, “Using static analysis to find bugs,” *IEEE software*, vol. 25, no. 5, pp. 22–29, 2008.
- [24] N. Ayewah and W. Pugh, “The google findbugs fixit,” in *Proceedings of the 19th international symposium on Software testing and analysis*, pp. 241–252, 2010.
- [25] M. R. Rahman, N. Imtiaz, M.-A. Storey, and L. Williams, “Why secret detection tools are not enough: It’s not just about false positives—an industrial case study,” *Empirical Software Engineering*, vol. 27, no. 3, p. 59, 2022.
- [26] S. K. Basak, K. V. English, K. Ogura, V. Kambara, B. Reaves, and L. Williams, “Assestharvester: A static analysis tool for detecting secret-asset pairs in software artifacts,” *arXiv preprint arXiv:2403.19072*, 2024.
- [27] J. Zhou, T. Zhang, and D. Lo, “Large language model for vulnerability detection: Emerging results and future directions,” in *Proceedings of the 46th International Conference on Software Engineering: New Ideas and Emerging Results (ICSE-NIER)*, 2024.
- [28] R. Bommasani, D. A. Hudson, E. Adeli, R. Altman, and et al., “On the opportunities and risks of foundation models,” *arXiv preprint arXiv:2108.07258*, 2021.
- [29] H. Husain, H.-H. Wu, T. Gazit, M. Allamanis, and M. Brockschmidt, “Codesearchnet challenge: Evaluating the state of semantic code search,” *arXiv preprint arXiv:1909.09436*, 2019.
- [30] D. Nguyen, L. Nam, A. Dau, A. Nguyen, K. Nghiem, J. Guo, and N. Bui, “The vault: A comprehensive multilingual dataset for advancing code understanding and generation,” in *Findings of the Association for Computational Linguistics: EMNLP 2023*, pp. 4763–4788, 2023.
- [31] Z. Feng *et al.*, “Codebert: A pre-trained model for programming and natural languages,” in *Findings of EMNLP*, 2020.
- [32] D. Guo, S. Ren, S. Lu, *et al.*, “Graphcodebert: Pre-training code representations with data flow,” in *Proceedings of the International Conference on Learning Representations (ICLR)*, 2021.
- [33] W. Ahmad, S. Chakraborty, B. Ray, and K.-W. Chang, “Unified pre-training for program understanding and generation,” in *Proceedings of the 2021 conference of the North American chapter of the association for computational linguistics: human language technologies*, pp. 2655–2668, 2021.
- [34] D. Guo, S. Lu, N. Duan, Y. Wang, M. Zhou, and J. Yin, “Unixcoder: Unified cross-modal pre-training for code representation,” *arXiv preprint arXiv:2203.03850*, 2022.
- [35] PyGithub Contributors, “PyGithub: Typed interactions with the GitHub API v3,” <https://github.com/PyGithub/PyGithub>, Feb. 2026.
- [36] E. Kalliamvakou, G. Gousios, K. Blincoe, L. Singer, D. M. German, and D. Damian, “The promises and perils of mining github,” in *Proceedings of the 11th working conference on mining software repositories*, pp. 92–101, 2014.
- [37] V. Cosentino, J. L. C. Izquierdo, and J. Cabot, “A systematic mapping study of software development with github,” *Ieee access*, vol. 5, pp. 7173–7192, 2017.
- [38] R. Artstein and M. Poesio, “Inter-coder agreement for computational linguistics,” *Computational linguistics*, vol. 34, no. 4, pp. 555–596, 2008.
- [39] X. Zhang, J. Zhao, and Y. LeCun, “Character-level convolutional networks for text classification,” *Advances in neural information processing systems*, vol. 28, 2015.
- [40] T.-Y. Lin *et al.*, “Focal loss for dense object detection,” in *Proceedings of ICCV*, pp. 2980–2988, 2017.